

Multi-Stage APT Attack: Simulation & Incident Response Report

Phase 1: Attack Simulation (Red Team)

1. Initial Access:

Gained entry via a spear-phishing email containing a malicious macro-enabled Word document. Execution of the macro exploited an unpatched vulnerability to drop the initial stager.

2. Persistence & Privilege Escalation:

Established persistence by creating a scheduled task (`schtasks /create /tn "WindowsUpdate" /tr "powershell.exe -w hidden -c ..."`). Escalated privileges by abusing PowerShell execution policies.

3. Lateral Movement:

Dumped LSASS memory to extract NTLM hashes. Utilized **Pass-the-Hash (PtH)** techniques and **PsExec** to move laterally to the domain controller and file servers.

4. Exfiltration:

Archived sensitive data and exfiltrated it to an external Command & Control (C2) server using covert **DNS Tunneling** and encrypted HTTP requests to evade legacy firewalls.

Phase 2: Attack Detection & Investigation (Blue Team)

1. Detection:

Security Onion & Wazuh generated critical alerts:

- Wazuh alerted on suspicious scheduled task creation (Rule ID: 92300).
- Security Onion (Zeek/Suricata) detected anomalous DNS queries indicating potential data exfiltration.

2. Hunting & Investigation:

Queried **Kibana** for the timeline of lateral movement, correlating Event ID 4624 (Logon) and 4688 (Process Creation) across multiple hosts. Created a case in **TheHive**, running **Cortex** analyzers on the extracted IP addresses and file hashes to confirm malicious reputation.

3. Reconstructed Attack Timeline:

- **09:00 AM:** Phishing email opened (Initial Access).
- **09:15 AM:** Malicious Scheduled Task created (Persistence).

- **10:30 AM:** PsExec execution detected on DC01 (Lateral Movement).
- **11:45 AM:** High volume of TXT records to external domain (Exfiltration).

Phase 3: Threat Intelligence & Mitigation

1. Threat Intelligence (MISP):

Extracted Indicators of Compromise (IoCs): Malicious IPs, Phishing Domains, and File Hashes. Shared these observables into the local **MISP** instance for community and inter-departmental awareness.

2. Defensive Rules (YARA & Sigma):

```
# Sigma Rule: Detect Malicious Scheduled Task via PowerShell
title: Suspicious PowerShell Scheduled Task
logsource:
  product: windows
  service: sysmon
detection:
  selection:
    EventID: 1
    CommandLine|contains:
      - 'schtasks'
      - 'powershell'
      - '-w hidden'
  condition: selection
```

3. Mitigation Plan & Remediation:

- **Immediate:** Isolate compromised endpoints from the network. Block malicious C2 IPs and domains at the firewall perimeter.
- **Short-Term:** Reset all compromised user credentials. Patch the exploited vulnerability across the environment.
- **Long-Term:** Enforce Multi-Factor Authentication (MFA), restrict PowerShell execution via AppLocker, and disable NTLM where possible to prevent Pass-the-Hash.

Conclusion: The incident response successfully contained the APT simulation, closing critical security gaps and deploying new detection logic to prevent future recurrence.